Risco na Nuvem

Introdução

Quando a previsão do tempo nos informa de que vai chover, se precisamos sair de casa rapidamente pegamos um guarda-chuva, mas e se a previsão informar de que se trata de uma chuva muito forte, daquelas capazes de destelhar uma residência? Acredito que um guarda-chuva normal não vai ser efetivo.

Isso significa que devemos compreender o tamanho, a forma e os impactos de cada risco que podemos sofrer, o que vale para as empresas que lidam com a computação na nuvem. E parte do processo de se compreender os riscos é conhecer o que temos que proteger contra estes riscos. Esse e outros temas importantes serão tratados nesta aula.

Objetivos da aula

- Conhecer o processo de identificação e avaliação de ativos;
- Compreender a importância da identificação das ameaças e vulnerabilidades;
- Conhecer os principais conceitos da construção de cenários de riscos e incidentes;
- Compreender o processo de confecção do plano de tratamento de riscos.

Resumo

Identificação e avaliação de ativos

Duas empresas que operam em um mesmo mercado consumidor podem ter riscos completamente diferentes. Se a localidade varia, vão variar os riscos e até mesmo a sua intensidade e possibilidade de incidência. E a empresa quando cria seus planos de continuidade, deve descobrir todos os possíveis riscos e os detalhar o melhor possível.

A identificação de riscos permite que a empresa encontre, reconheça e descreva quais são os riscos, com base em um contexto estabelecido, apoiado por comunicação e consulta de seu ambiente interno e externo. Portanto, podemos afirmar que o objetivo é desenvolver uma lista abrangente de riscos, suas causas, suas fontes e determinar quais eventos podem afetar o alcance dos objetivos identificados na etapa de contextualização.

Para TCU (2018, *apud* NOVAIS FERRAZ 2019, p. 63), o primeiro passo deve ser a identificação dos riscos, usando uma abordagem de cima para baixo, do mais geral ao mais específico. Primeiro, identifique os riscos em um nível geral ou superior como ponto de partida para definir prioridades, depois identifique e analise os riscos em um nível específico e/ou mais detalhado. A identificação de riscos pode ser baseada em dados históricos, análise teórica, opinião de especialistas informados e necessidades das partes interessadas.

Neste momento a empresa deve criar as equipes que vão se dedicar a esta análise sempre levando em conta as habilidades, soft e hard skills de cada um, pois é preciso que tenham conhecimento adequado na identificação de riscos, e no uso de ferramentas e técnicas de identificação de riscos apropriadas para seus objetivos, capacidades e riscos. Assim como um projeto formal, esta etapa deve ser documentada e contém os seguintes elementos mínimos:

- O escopo do processo, projeto ou atividade coberto pela identificação;
- Os participantes do processo de identificação;
- A abordagem ou o método utilizado para identificação dos riscos e as fontes de informação consultadas;
- O registro dos riscos identificados em sistema, planilha ou matriz de avaliação de riscos, descrevendo os componentes de cada risco separadamente com, pelo menos, suas causas, o evento e as consequências. (NOVAIS FERRAZ 2019, p. 64).

Vale ressaltar que existem alguns itens que demandam uma apuração ativa, como as ameaças, as vulnerabilidades e impactos, tal como estabelecem os especialistas da Agência de Segurança da Informação e Informática e pareceres relacionados aos Departamento de Defesa Comercial (DECOM) responsáveis pelos SDDs, e que identificam as seguintes etapas do processo de identificação dos riscos:

- Identificar ativos;
- Identificar ameaças;
- Identificar controles existentes;
- Identificar vulnerabilidades;
- Identificar as consequências. (NOVAIS FERRAZ 2019, p.65).

A Defesa Civil sempre oferece um detalhamento das zonas de risco de cada município brasileiro e estas informações podem ser obtidas nos seus portais web regionais. Desta forma a empresa já consegue descobrir se a região onde está fisicamente instalada é suscetível a alagamentos, deslizamentos de terra e outros desastres naturais.

Identificação de ameaças e vulnerabilidades

Com os grandes benefícios da computação em nuvem existem as grandes ameaças, pois com a crescente transformação digital das empresas, a maior presença de ativos digitais na nuvem vem atraindo hackers e aumentando os riscos e ameaças.

Apesar dos grandes benefícios que a computação em nuvem oferece, o uso em larga escala da computação em nuvem levantou novas preocupações sobre novas situações de segurança e privacidade. Devido à natureza de suas operações, parte da infraestrutura de tecnologia da informação (TI) e recursos de computação do provedor estão disponíveis para os assinantes do serviço.

Isso pode representar uma ameaça potencial, mesmo que o contratado esteja agindo de boa fé. Nesta seção, examinamos aspectos de segurança mais específicos das operações em nuvem, mas não especificamente para esses serviços, mas questões gerais de segurança que tradicionalmente desafiam o pessoal técnico de segurança. Comece abordando o problema. De acordo com Hiran et al. (2019 apud Silva, 2020, p.247), esses desafios incluem:

- Violações de dados: acesso aos dados por quem não tem autorização para tanto e usa de meios fraudulentos para obtê-lo.

- Falha no gerenciamento de identidade: identidades mal resolvidas pelo sistema de segurança podem dar acesso a dados e recursos para quem não deveria tê-lo, mesmo afastada a má-fé no acesso.

- Vulnerabilidades do sistema: as atualizações do sistema operacional devem ser baixadas e executadas assim que

estiverem disponíveis, a fim de minimizar a exploração de suas vulnerabilidades.

- Sequestro de conta: ameaça que se efetiva com o roubo e o uso da conta de um usuário legítimo para fins maliciosos. (SILVA, 2020, p.248).

Para Bhowmik (2017 apud Silva, 2020, p.249), podemos exemplificar uma situação de ameaça em um ambiente de nuvem, como sendo,

> [...] uma pessoa com pertences valiosos expostos publicamente certamente chamaria a atenção de gente com intenções nada escrupulosas, o que poderia colocar em risco a posse de seus pertences e sua integridade física. Em sentido amplo, esse é o risco que uma organização corre quando dados sensíveis são movimentados do interior de uma organização para a nuvem, ou em sentido inverso.

Aprofundando no tema, é possível desdobrar esses riscos e em seguida, agrupar por tipo de serviço oferecido pelo provedor. A oferta de SaaS (Software como um Serviço), por exemplo, tem o potencial de abrir brechas significativas, gerando potenciais ameaças próprias desse serviço em nuvem.

Um dos principais problemas, ou seja, vulnerabilidades da nuvem SaaS é a falta de transparência sobre quais dados estão nos aplicativos em nuvem, pois tais dados são mantidos pela aplicação, que por sua vez provê de inúmeras vulnerabilidades próprias, motivo pelo qual podem ser ilegais ou até mesmo roubados de alguma outra organização; afinal, não se sabe o que uma simples planilha Excel pode conter.

De acordo com Silva (2020), o roubo de dados de aplicativos em nuvem por agentes mal-intencionados representa outro grande problema, pois embora seja uma ameaça comum, é a ocorrência mais provável devido à extensão da divulgação desses dados. Outra questão relevante é o fato

de que não é possível monitorar dados em trânsito de/para aplicativos em nuvem, onde a responsabilidade dos provedores pelos aplicativos e pelos dados que eles mantêm é limitada à extensão de sua infraestrutura. Isso significa que o provedor não pode impedir ataques enquanto esses ativos estiverem em trânsito pela Internet. (SILVA, 2020)

Cenários de riscos e incidentes

De acordo com a ISACA (2009 *apud* Lima 2018, p.16), um dos desafios da gestão de riscos de TI é identificar todos os riscos relevantes. Uma solução para enfrentar esse desafio é o desenvolvimento e uso de cenários de risco. Depois que esses cenários são criados, eles são usados durante a análise de risco para estimar a frequência com que ocorrerão e seu impacto nos negócios.

Existem vários caminhos para riscos e incidentes no espaço tecnológico, e o ambiente de computação em nuvem não é exceção. Isso ocorre porque os ambientes de computação em nuvem são as infraestruturas com maior probabilidade de precisar lidar com ambientes críticos, onde manter as informações disponíveis é essencial. Devemos sempre lembrar que os riscos não são apenas técnicos, mas também físicos, como deslizamentos, enchentes, terremotos, etc.

Desta forma, é importante que os gestores conheçam os principais pontos de segurança para sua empresa, como seus mecanismos de controle de acesso físico, estabilidade de temperatura do ambiente de armazenamento de dados no qual o dispositivo está localizado, etc. Assim, uma vez que um conjunto de cenários de risco tenha sido definido e disponibilizado para análise de risco, a frequência e o impacto dos cenários são avaliados (LIMA 2018).

Figura 1: Desenvolvimento de cenários de riscos de TI.



Fonte: Adaptado de ISACA (2009, p. 25; LIMA 2018, p.18)

Para Lima (2018), em cada cenário avaliado temos a perspectiva da relevância e realidade incluídas na lista de riscos conforme apropriado. Na prática, isso geralmente não é possível, pois leva a um grande número de cenários. O número de cenários a serem desenvolvidos deve ser mantido gerenciável para que o tratamento dos riscos mais relevantes possa ser priorizado por questões orçamentárias.

Segundo Roxburgh (2009 apud Lima 2018, p.19), os cenários oferecem três vantagens muito importantes na compreensão de riscos e oportunidades. Primeiro, os cenários ampliam o pensamento. Chegar a uma gama de resultados possíveis faz com que as pessoas pensem de forma mais ampla. Ao mostrar como e por que as coisas podem mudar, você pode se preparar para muitas possibilidades no futuro.

Em segundo lugar, o cenário revela um futuro inevitável ou quase inevitável. Ao criar cenários, as pessoas buscam resultados

predeterminados, especialmente os inesperados. Esses resultados são muitas vezes a fonte de novos conhecimentos revelados ao longo do caminho (LIMA 2018).

E, finalmente, os cenários são importantes por permitirem uma interessante forma de proteção, a proteção contra o pensamento coletivo, onde as hierarquias organizacionais geralmente impedem o fluxo livre da discussão. Os funcionários (especialmente em reuniões) esperam que a gerência sênior fale o que pensam antes de se arriscarem a falar o que pensam.

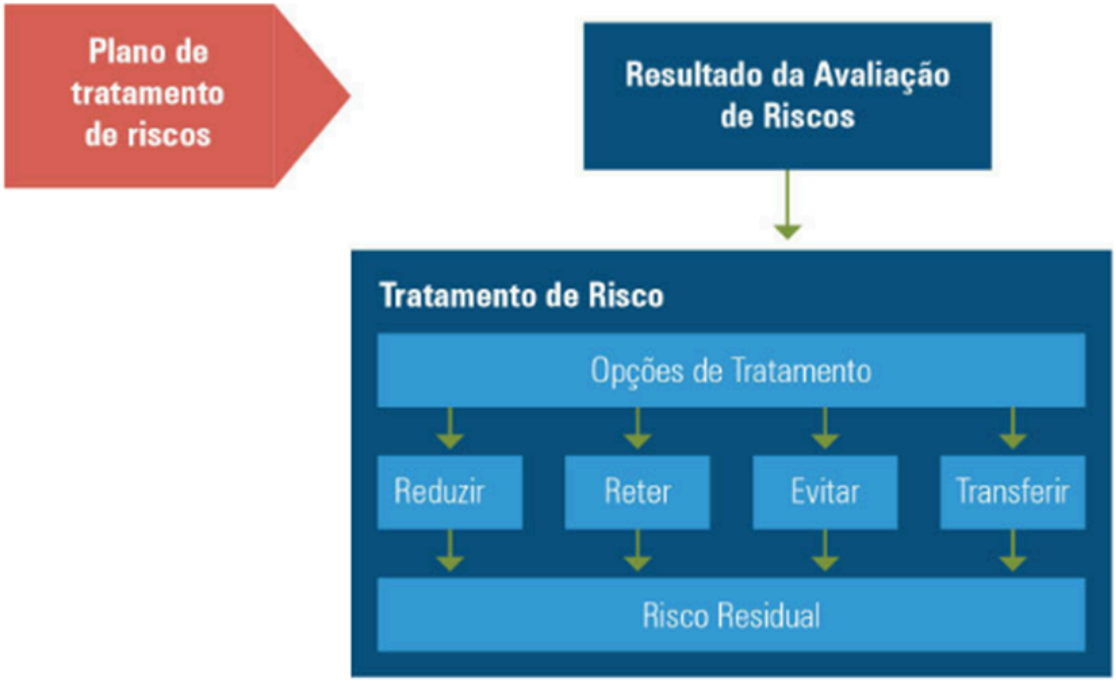
Os cenários permitem que as organizações saiam dessa armadilha, fornecendo um porto seguro para a liberdade de expressão. Os cenários não fornecem todas as respostas, mas geram perguntas cada vez melhores e mais abrangentes. Isso o torna uma ferramenta muito valiosa.

Plano de tratamento de riscos

Um plano de tratamento de riscos ajuda a identificar medidas, recursos, responsabilidades e prioridades apropriados para gerenciar riscos de segurança. Todos os controles planejados devem ser incluídos no plano de tratamento de riscos. O plano de tratamento de riscos deve ser apresentado às principais partes interessadas para que estejam cientes das responsabilidades e prioridades do planejamento de riscos.

O objetivo não é eliminar completamente o risco, pois tal como defende Lima (2018), deve reduzi-lo a um nível aceitável. Controles que não são razoáveis do ponto de vista do negócio. Desta forma, os esforços de implementação que não são justificáveis do ponto de vista da análise de custo-benefício não devem ser implementados e cabe à organização aceitar ou evitar os riscos.

Figura 2: Plano de tratamento de riscos.



Fonte: Adaptado de IBGC (2007; LIMA 2018, p.23).

De forma geral, temos as seguintes formas para o tratamento de risco dentro de um plano estratégico:

- Reduzir ou mitigar: aplicação de um controle para que o risco seja considerado aceitável.
- Reter ou aceitar: caso o risco atenda aos critérios para aceitação, ele poderá ser retido.
- Evitar: o risco pode ser evitado por meio da eliminação da atividade ou do processo de negócio ou de uma mudança significativa no ambiente (ex.: mudar um data center de lugar).
- Transferir: O risco pode ser transferido para uma outra entidade (ex: contratação de um seguro ou terceirização). É importante lembrar que não se pode transferir completamente a responsabilidade pela segurança da informação. (LIMA 2018, p.24).

Os planos de tratamento de riscos são criados pela gestão de projeto ou pela equipe encarregada da gestão de TI, desta forma, este pessoal de TI

captura todos os riscos possíveis em um ambiente de computação em nuvem e fornecem opções para gerenciá-los e conseguir mitigar, reter, evitar ou transferir riscos.

Como aplicar na prática o que aprendeu

Como o *Ethical Hacking* pode ajudar na gestão do risco?

Com as técnicas hacker sendo utilizadas para o teste da segurança das plataformas digitais e de computação em nuvem a empresa se prepara melhor para os ataques reais, um risco cada vez maior de ocorrer.

Seja apenas com os testes de penetração, ou com uma vasta lista de técnicas, atuar com *Ethical Hacking* está cada vez mais promissor, pesquise mais sobre a profissão, desenhe sua trilha para atuar na área e tenha grande sucesso.

Conteúdo bônus

Tópicos avançados

Compreendendo melhor os detalhes de uma matriz de plano de Gestão de Risco.

Este artigo trabalha com o gerenciamento de riscos de tecnologia da informação (TI), e de como usar um conjunto de métodos ou processos para identificar, avaliar e controlar ameaças aos ativos de TI. A maioria dos processos institucionais opera em ambiente digital e, paralelamente a esta digitalização dos processos organizacionais, introduzem-se os riscos que a TI pode representar para as instituições.

Aproveite o ótimo artigo cujo título é “Plano de Gestão de Riscos de Tecnologia da Informação (TI)”.

Observação: Este conteúdo não será cobrado nas avaliações e estará, obrigatoriamente, presente nas videoaulas. Fique tranquilo(a)!

Referência Bibliográfica

ISO, ABNT ABNT NBR: Iec 31000-2009: **Gestão de riscos-princípios e diretrizes.** norma técnica. Technical report, ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS, Rio de Janeiro, Brasil, 39(4):2, 2009. 16, 26, 27, 32, 54, 55, 59, 63, 64, 67, 70, 73.

LIMA, Adriano Carlos de**. Segurança na computação em nuvem**. - Editora Senac São Paulo, 2018.

NOVAIS FERRAZ, Claudio Augusto. **Gestão de Riscos em Computação em Nuvem para a Gestão de Identidade e Acessos aplicada ao Sistema Decom Digital do Ministério da Economia**. - Brasília, 2019. Disponível em: <https://repositorio.unb.br/bitstream/10482/37502/1/2019_ClaudioAugustoNovaisFerraz.pd Acesso em: 28 de dezembro de 2022.

SILVA, Fernanda Rosa da... [et al.]. **Cloud Computing**. – Porto Alegre: SAGAH, 2020.

Ir para questão